HE 5020 — PRACTICA 4 (UT5, SESION 2): ENUMERACION ACTIVA DE TECNORIBERA (RED TEAM BASICO)

META

Hasta hoy en HE habeis hecho OSINT pasivo: buscar sin tocar, agregar con fuente, grafo, falsos positivos. Buen trabajo. Pero el OSINT solo te lleva hasta la puerta de la empresa. A partir de ahora empiezan los paquetes, el ruido y las huellas. Hoy haceis EL SALTO: dejais de "mirar" y empezais a "preguntar al servidor". Toda pregunta se registra en algun sitio y, si el defensor hace bien su trabajo, dispara una alerta.

Para que la cosa tenga sabor a realidad, el objetivo no es un target abstracto: es TECNORIBERA, S.L. — la misma empresa que vuestros compañeros de IC pusieron ayer bajo vigilancia con Wazuh. Son las 09:00 del dia D del pentest. ROE firmado. Alcance acotado. El SOC esta encendido y ellos estan tomando cafe pensando que no pasa nada. Vamos a ver cuanto tardan en darse cuenta.

Al terminar la sesion debeis poder enseñar, uno a uno:

- Un informe pasivo institucional del dominio tecnoribera.local (subdominios, correos, certificados, lo que se ve desde Internet) con fecha y fuente.
- Un inventario activo HE-E10 con host, puerto, servicio, version y evidencia por cada hallazgo.
- Vuestra decision de "cuanto ruido estais dispuestos a hacer" y por que (velocidad vs sigilo).
- Al menos tres hallazgos distintos verificados a mano (no "lo dice el escaner y ya").
- La comparacion con los compañeros de IC: cuantas alertas disparo cada tecnica, y a que level.
- La version "limpia" del laboratorio al salir (habeis llegado, habeis mirado, habeis anotado, y OS HABEIS IDO sin dejar basura).

Trabajo en parejas. Uno ejecuta, otro verifica Y toma notas. Cambiais en cada bloque. El que anota es tan importante como el que teclea: en un informe de pentest de verdad lo que no esta documentado no existe.

EL ESCENARIO

TECNORIBERA, S.L. os ha contratado para un pentest externo de caja gris. Os han dado:

- El dominio corporativo: tecnoribera.local (laboratorio aula; en una empresa real seria tecnoribera.com).
- Un rango de IPs del portal corporativo: lo da el profesor al principio de la sesion (variable IP_PORTAL / RANGO_PORTAL del aula).
- El ROE firmado (HE-E1 de la semana 2). Si no esta firmado NADIE EJECUTA NADA.

Objetivos del pentest de hoy:

- Reconocer la superficie externa: que servicios expone TECNORIBERA desde fuera.
- Enumerar version y configuracion de cada servicio alcanzable.
- Preparar el terreno para la UT6 (explotacion) y UT8 (auditoria web): sin inventario, no hay ataque.

Objetivos que estan FUERA de alcance hoy:

- Explotar lo que encontreis. Ni probar credenciales por defecto, ni abrir reverse shells, ni tocar nada que modifique estado. Hoy no se vulnera, hoy se mapea.
- Enumerar ninguna maquina que no sea el rango que da el profesor. Un nmap a Google "para probar" es fuera de alcance = 0.
- OSINT sobre PERSONAS de la empresa. Hoy es sobre la infraestructura. OSINT sobre personas requiere consentimiento (lo visteis la semana pasada en la S1 de UT5).

REGLAS DURAS (NO NEGOCIABLES)

Antes de empezar, estas tres reglas se recitan en voz alta por la pareja. Si no las entendeis, se para la clase.

1. Sin ROE firmado no hay accion activa. El ROE es el papel que convierte lo que hariais fuera de aqui en delito (art. 197/264 CP) en un trabajo autorizado.
2. Count=0 cuenta. Si una herramienta no devuelve resultados pero HAS demostrado que la consulta funciono (p.ej. con un target de control), ese "cero" ES un hallazgo. Un cero sin verificacion es un error, no un cero.
3. Un hallazgo sin fuente y sin marca de tiempo no es un hallazgo, es un rumor. Cada linea del inventario HE-E10 tiene que decir: que comando lo produjo, cuando, y como lo verificaste a mano.

HERRAMIENTAS QUE NECESITAS

Todas vienen en Kali Linux (que es la distro del aula). Si vuestra Kali esta sin tocar desde el mes pasado, lanzad primero:

```
sudo apt update
sudo apt install -y nmap whatweb wafw00f dnsutils whois
```

Para las herramientas de ProjectDiscovery (subfinder, httpx, nuclei, ffuf), verificad y actualizad:

pdtm -ua
nuclei -update-templates

Si pdtm no esta, lo instalais:

go install github.com/projectdiscovery/pdtm/cmd/pdtm@latest
export PATH=$PATH:$HOME/go/bin

Comprobacion rapida de que teneis el arsenal basico:

nmap --version # 7.9x o superior
subfinder -version
httpx -version
ffuf -version
nuclei -version
whatweb --version

Si alguna de estas falla, se instala AHORA, no en mitad del escaneo.

BLOQUE 0. OSINT INSTITUCIONAL — "GRATIS E INVISIBLE"

Antes de encender un solo paquete contra TECNORIBERA, agotad lo pasivo. Esto es lo que diferencia a un consultor profesional de uno que llega y lanza nmap: antes de molestar al cliente, se mira todo lo que ya esta publicado. En una empresa real, lo pasivo es GRATIS, LEGAL y NO DEJA RASTRO en el SOC del cliente. En este laboratorio tiene menos chicha porque el dominio es ficticio, pero el METODO es el mismo que usariais contra "bbva.es" o "tecnoribera.com".

0.1 Certificados emitidos para el dominio (crt.sh)

Transparencia de certificados: cada vez que una CA emite un cert, se publica en logs publicos. Es la mejor fuente de subdominios "ocultos".

curl -s "https://crt.sh/?q=%25.tecnoribera.local&output=json" | jq -r '.[].name_value' | sort -u

Si estamos contra el dominio ficticio del aula, probablemente devuelva vacio. Eso es un cero verificado (regla 2) y lo apuntais asi. Repetid el comando contra un dominio real conocido (p.ej. tu propio dominio o uno del centro) para demostrar que la consulta funciona cuando hay datos.

0.2 Agregadores de subdominios (subfinder)

subfinder va a 20+ fuentes publicas (crt.sh, Shodan, VirusTotal, etc.):

subfinder -d tecnoribera.local -silent | tee subs_pasivos.txt

0.3 Correos y hosts citados en Internet (theHarvester)

theHarvester -d tecnoribera.local -b crtsh,duckduckgo,yahoo,bing

0.4 Whois y DNS basicos

whois tecnoribera.local
dig +short NS tecnoribera.local
dig +short MX tecnoribera.local
dig +short TXT tecnoribera.local

El TXT suele regalar la configuracion de correo (SPF, DMARC, DKIM): si no tienen DMARC, puedes falsificar su dominio en spear-phishing. Es un hallazgo de informacion util para la UT6, apuntadlo.

0.5 Que se registra de todo esto en el SOC

NADA. Las consultas pasivas van contra servicios de internet (crt.sh, DNS publicos). El servidor de TECNORIBERA no ha recibido ni un paquete vuestro. El analista SOC de enfrente no ve nada todavia. Esto es lo que teneis que grabaros: la cantidad de informacion que se puede sacar sin molestar al target es ENORME. Lo escaso en el pentest profesional no es "herramientas"; es "paciencia pasiva".

Documentad TODO en pasivo-tecnoribera.md con fecha y comando. Vamos al salto.

BLOQUE 1. EL SALTO — "A PARTIR DE AQUI, CADA PAQUETE DEJA HUELLA"

Lo repetis en voz alta antes de pulsar enter en el primer nmap: "a partir de ahora, el SOC puede verme".

En el mundo real, esto es el momento mas delicado del pentest. Un atacante prudente lo retrasa dias. Un pentester con ROE firmado solo tiene que avisar al cliente ("empiezo el activo a las 10:00") y empezar; pero el ritmo lo elige. El ritmo del escaner marca el nivel de ruido:

- Rapido (-T4 o -T5): acabas antes, el SOC se da cuenta en 30 segundos.
- Normal (-T3, por defecto): equilibrado.
- Lento (-T2): el SOC puede confundirlo con trafico legitimo si no afinan reglas.
- Paranoico (-T1 o -T0): invisibles para la mayoria de SOCs pero puedes tardar horas por host.

Hoy vamos a HACER LOS DOS: una pasada rapida (ruidosa) y otra lenta (sigilosa). Despues compararеis con IC cuanto ruido genero cada una. Esto es el nucleo del juego rojo↔azul.

BLOQUE 2. NMAP — DESCUBRIMIENTO Y PUERTOS

nmap es el martillo del pentester. Hace una docena de cosas y las hace bien. Las cuatro mas comunes:

2.1 Descubrimiento de hosts vivos (sin tocar puertos)

sudo nmap -sn -PE -PP -PS80,443 -PA443 IP_RANGE_PORTAL -oA 02-descubrimiento

Que hace, en castellano:

- -sn: NO escanea puertos, solo "esta vivo el host".
- -PE: ping ICMP echo.
- -PP: ping ICMP timestamp (algunos cortafuegos filtran PE pero dejan PP).
- -PS80,443 / -PA443: TCP SYN y TCP ACK a puertos tipicos como fallback.
- -oA 02-descubrimiento: guarda la salida en tres formatos (nmap/.gnmap/.xml). TODO escaneo se guarda.

Resultado: lista de IPs vivas. Esas son vuestros objetivos reales. El resto no existe (hoy).

2.2 Puertos abiertos (rapido, ruidoso)

sudo nmap -sS -T4 --top-ports 1000 IP_PORTAL -oA 03-nmap-rapido

Que hace:

- -sS: SYN scan (semiabierto). No completa el handshake, es mas rapido y menos "educado" que -sT.
- -T4: timing agresivo. El SOC lo va a ver muy claro.
- --top-ports 1000: los 1000 puertos mas probables (los 65535 completos tardan muchisimo).

Mirad cuanto tarda. Lo apuntais. Luego compararеis con el lento.

2.3 Puertos abiertos (lento, sigiloso)

sudo nmap -sS -T2 -f --data-length 25 --top-ports 1000 IP_PORTAL -oA 04-nmap-lento

Nuevo en este comando:

- -T2: timing "polite". Mete esperas entre paquetes.
- -f: fragmenta los paquetes IP. Algunos IDS mal configurados pierden el rastro.
- --data-length 25: añade 25 bytes de relleno. Rompe firmas basicas que detectan nmap por tamaño de paquete.

Cuanto tarda esta? Un orden de magnitud mas. Ahora el que esta de guardia en IC puede que ni se entere.

2.4 Version y servicios de cada puerto abierto

Cuando sabeis que puertos estan abiertos, los interrogais a fondo:

sudo nmap -sV -sC --version-intensity 7 -p PUERTOS_ENCONTRADOS IP_PORTAL -oA 05-nmap-versiones

Que hace:

- -sV: fingerprint de version. "Apache 2.4.52, Ubuntu".
- -sC: ejecuta el conjunto "default" de scripts NSE. Muchos descubrimientos utiles vienen de aqui (banners, titulos HTTP, SMB OS discovery, etc.).
- --version-intensity 7: lo pregunta todo (0 = nada, 9 = todo).
- -p: la lista de puertos que encontraste abiertos en 2.2 o 2.3. NO -p-: no re-escanees los 65535 por version.

Que te interesa de la salida:

- Version exacta del servicio. Es la llave para buscar CVEs (lo haras en UT2).
- Software extraño o antiguo. Un IIS 6.0, un OpenSSH 5.x, un Apache 2.2: todo huele a maquina olvidada.
- Banners con informacion de mas: hostname interno, nombre de la organizacion, email del admin.

2.5 Scripts NSE utiles para hoy (sin pasarse)

Scripts seguros que SOLO leen:

sudo nmap --script http-title,http-headers,http-methods,ssl-cert,ssl-enum-ciphers -p 80,443 IP_PORTAL
sudo nmap --script smb-os-discovery,smb-security-mode -p 445 IP_PORTAL

NO uses hoy: scripts "intrusive", "exploit", "brute" o "auth". Esos vulneran o adivinan; eso es UT6, no hoy.

BLOQUE 3. FINGERPRINTING WEB

Si el puerto 80 o 443 estan abiertos, el 90% del valor del pentest externo esta ahi. Dedicadle tiempo.

3.1 httpx: respuesta y fingerprint

echo IP_PORTAL | httpx -title -tech-detect -status-code -server -ip -cl

Que hace:

- -title: titulo HTML.
- -tech-detect: tecnologia detectada (Wappalyzer-like: WordPress, Django, nginx, PHP X.Y).
- -status-code, -server, -ip, -cl: codigo HTTP, header Server, IP destino, Content-Length.

Si teneis varios subdominios de la fase pasiva, pasadselos todos:

cat subs_pasivos.txt | httpx -title -tech-detect -status-code

httpx es muy rapido. Un alumno con buen inventario cierra el fingerprint de 50 subdominios en 2 minutos.

3.2 whatweb: fingerprint alternativo

whatweb -a 3 http://IP_PORTAL

whatweb puede detectar plugins concretos (ej. versiones de WordPress plugins) que a httpx se le escapan. Es menos moderno pero muy util.

3.3 wafw00f: hay WAF por delante?

wafw00f https://IP_PORTAL

Si hay un WAF (Cloudflare, F5, AWS WAF, ModSecurity), vuestros siguientes pasos cambian: muchas firmas de nuclei las va a bloquear o devolver 403. Es informacion que tienes que saber ANTES de lanzar lo pesado.

BLOQUE 4. FUZZING DE RUTAS Y SUBDOMINIOS CON FFUF

ffuf descubre lo que no esta linkado en las paginas. Login panels, directorios de admin, backups olvidados, APIs internas: todo eso suele vivir en rutas que no estan en el menu.

4.1 Rutas comunes con una wordlist pequeña

ffuf -u http://IP_PORTAL/FUZZ -w /usr/share/wordlists/dirb/common.txt -mc 200,204,301,302,307,401,403 -o 06-ffuf-rutas.json

Que hace:

- -u http://IP_PORTAL/FUZZ: el placeholder FUZZ se sustituye por cada palabra de la wordlist.
- -w: wordlist. common.txt es pequeña (4600 palabras); para profundizar luego, big.txt o seclists.
- -mc: match codes. Lo que incluimos como "hallazgo". NO uses solo 200: un 403 ("no autorizado") delata que la ruta EXISTE pero no te deja entrar; un 401 pide auth; un 301/302 redirige a algo nuevo.

Que hacer con los resultados: cada ruta no trivial se abre A MANO en el navegador. Nunca os fieis del codigo HTTP solo. Un 200 puede ser la pagina de error. Un 403 puede ser un panel admin super interesante.

4.2 Subdominios por fuerza bruta DNS

Si teneis el DNS del aula apuntando a *.tecnoribera.local:

ffuf -u http://FUZZ.tecnoribera.local -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt -H "Host: FUZZ.tecnoribera.local" -mc 200,301,302,401,403

Si no, haced el mismo fuzzing contra el servidor que resuelve.

Cada subdominio encontrado va al inventario.

BLOQUE 5. ESCANER DE VULNERABILIDADES — NUCLEI

nuclei no "explota": comprueba condiciones (p.ej. "este header leak de version es signatura de CVE-X"). Es rapido y muy ruidoso. Pensado para producir un inventario de banderas rojas que luego investigas a mano.

5.1 Pasada basica (severidad info/low/medium)

nuclei -u http://IP_PORTAL -severity info,low,medium -o 07-nuclei-base.txt

Esto suele devolver mucho ruido util: tecnologia detectada, headers de seguridad ausentes,

versiones expuestas en banners, listados de directorios abiertos.

5.2 Pasada "lo que importa"

nuclei -u http://IP_PORTAL -severity high,critical -o 08-nuclei-criticos.txt

Aqui es donde salen (si existen) CVEs conocidos y configuraciones gravemente malas. 90% de lo que un pentest "real" devuelve en 3 dias es un buen inventario de nuclei + verificacion manual.

5.3 La regla que SIEMPRE SE OLVIDA

Cada hallazgo que escupe nuclei TIENE QUE VERIFICARSE A MANO antes de ponerlo en el informe. Los falsos positivos de nuclei son incomodos pero existen (plantillas obsoletas, matches por casualidad, servicios proxyados). Entregar un informe con un falso positivo es la forma mas rapida de perder un cliente.

Para cada hallazgo nuclei:

1. Lee la plantilla (-templates templates/.../plantilla.yaml) y entiende QUE comprueba.
2. Reproducelo a mano con curl y mira la respuesta en crudo.
3. Si no te convence, descartalo. Si te convence, lo subes de prioridad para la UT6.

BLOQUE 6. ENUMERACION DE SERVICIOS INTERNOS (SOLO SI PROCEDE)

Si en el nmap aparecio SMB (445), RDP (3389), SSH (22), FTP (21), bases de datos (3306, 5432, 1433) o directorio activo (389, 636), toca enumerar segun el servicio. Hoy nos limitamos a SMB como demo (en empresas reales suele estar expuesto por error):

6.1 SMB

enum4linux-ng -A IP_PORTAL -oY 09-smb.yaml

Esto saca: shares, usuarios, politicas de contraseñas, OS. Si sale una share sin auth con contenido, lo apuntais pero NO lo descargais hoy (eso es ya accion sobre datos, UT6).

BLOQUE 7. JUEGO ROJO ↔ AZUL (EL BLOQUE MAS INTERESANTE DEL DIA)

Mientras vosotros ejecutabais, los compañeros de IC (que ayer montaron el SOC de TECNORIBERA con Wazuh) estaban mirando el dashboard. Ahora los juntamos y comparais.

7.1 Que ha visto IC

Preguntadles para cada bloque:

- Bloque 2.2 (nmap rapido -T4): cuantas alertas disparo? De que nivel? Les salto "possible port scan" / rule 40601 o similar?
- Bloque 2.3 (nmap lento -T2 -f --data-length): salieron las mismas alertas? Tardaron en encenderse? O no las vieron en absoluto?
- Bloques 4.1 y 4.2 (ffuf rutas y subdominios): ffuf genera miles de requests. Cuantos 404 vieron pasar? El dashboard web del portal les delato?
- Bloque 5 (nuclei): mas o menos alertas que nmap?
- Bloque 6 (enum4linux): les llego alguna alerta de SMB?

7.2 La leccion

Esto es lo mas importante que os llevais hoy:

- Enumerar NO ES GRATIS. Deja huella medible, cuantificable, en el log del cliente.
- La velocidad es una decision estrategica, no "lo mas rapido mejor". A veces 20 minutos de -T2 valen mas que 5 segundos de -T5 saltando todas las alertas.
- El atacante bueno pasa inadvertido tanto tiempo como puede. El pentester bueno sabe hacer las dos: muestra lo ruidoso Y lo sigiloso, para que el cliente sepa que ambos existen.

7.3 Que apuntais en vuestro informe

En el apartado "medicion de ruido" del HE-E10, lineas tipo:

- nmap -T4 contra 192.168.X.Y: 1 host x 1000 puertos. Tiempo: 18 s. Alertas en Wazuh: 1 (rule 40601 "Nmap scan", level 10). Tiempo hasta la primera alerta: 4 s.
- nmap -T2 -f --data-length 25 misma IP: tiempo 7 min. Alertas en Wazuh: 0 (no cruzo umbral). CONCLUSION: a este SOC con las reglas actuales le pasa desapercibido un escaneo lento con fragmentacion.

Esto es ORO para un cliente real. "Vuestro SOC detecta lo torpe pero no lo profesional" es la frase que vende un servicio adicional de tuning de reglas.

BLOQUE 8. INVENTARIO HE-E10 (ENTREGABLE)

Rellenad plantilla-inventario-HE-E10.md (o un markdown propio) con esta estructura. Minimo 10 lineas. Cada linea tiene fuente, comando y verificacion a mano.

| Host / dominio | Puerto | Protocolo | Servicio | Version | Hallazgos | Como lo verifique |

Fecha/hora |

Ejemplo:

| 192.168.X.10 | 22 | TCP | OpenSSH | 8.9p1 Ubuntu 3ubuntu0.6 | Banner expone version exacta y SO | nmap -sV + nc 192.168.X.10 22 (banner coincide) | 22-oct-26 10:14 |

Pregunta de autocritica (va al informe): ¿hay algun hallazgo "porque lo dice el escaner" que NO verificaste a mano? Si lo hay, no lo entregues. Si lo entregas, ponle una nota "sin verificar a mano" — eso te salva en una revision tecnica.

BLOQUE 9. HIGIENE POST-ENGAGEMENT

Un buen pentester se va sin dejar rastro operativo. Hoy, como no habeis explotado, es muy facil, pero fijad el reflejo:

- Cierra sesiones abiertas, limpia terminales (history -c si trabajas en una maquina compartida del aula).
- Elimina credenciales temporales (ninguna hoy).
- Archiva las salidas de los comandos en una carpeta datada: engagement-tecnoribera-2026-10-22/.
- Avisa al cliente de que el activo termino. En clase: avisa al profesor para que lo refleje en el runbook del aula.

Si en algun momento tocais algo que no debiais, se dice SIEMPRE. Un pentester que oculta un error pierde el contrato. Un pentester que lo cuenta a tiempo mantiene al cliente.

BLOQUE 10. ENTREGA Y CIERRE

Carpeta de entrega NN-HE-UT5-S2/:

- pasivo-tecnoribera.md
- 02-descubrimiento.nmap/gnmap/xml
- 03-nmap-rapido.nmap/gnmap/xml
- 04-nmap-lento.nmap/gnmap/xml
- 05-nmap-versiones.nmap/gnmap/xml
- 06-ffuf-rutas.json
- 07-nuclei-base.txt
- 08-nuclei-criticos.txt
- 09-smb.yaml (si procede)
- inventario-HE-E10.md

- medicion-ruido.md (del Bloque 7)
- bitacora.md

En bitacora.md debe aparecer:

- Alumno/grupo:
- IP del portal objetivo:
- ¿ROE firmado?: SI (si no, no entregais nada: la practica no se ha hecho).
- Comandos ejecutados por orden cronologico (SOLO los activos; los pasivos aparte).
- Que verifique a mano y que no.
- Hallazgo mas interesante del dia y por que:
- Punto ciego: ¿que no habeis podido mirar y por que?
- Que cambiarias si fuera un pentest real (minimo 3 cosas):

NO TE VAYAS CON UN ERROR OCULTO

Si algo no funciona, documenta antes de pedir ayuda:

1. Comando ejecutado.
2. Salida exacta.
3. Que esperabas.
4. Donde has mirado.
5. Que cambio lo arreglo.

Un red teamer no es "el que lanza exploits". Es el que documenta cada paso con tal precision que un auditor puede repetirlo mañana y obtener el mismo resultado. Si tus escaneos no son reproducibles, no son profesionales.

PREGUNTAS DE CIERRE (VERBAL, POR PAREJAS)

1. ¿Por que la fase pasiva es irrenunciable aunque "no de hallazgos"? ¿Que ganas que no se ve en el inventario?
2. ¿Que diferencia operativa hay entre -T4 y -T2 contra un SOC decente? ¿Cuando elegirias cada uno?
3. nuclei dice "critical" en una pagina y al abrirla a mano con curl ves que no es tan critical. ¿Que haces? ¿Lo entregas, lo descartas, lo marcas como no verificado?
4. ¿Por que no debeis probar credenciales por defecto hoy aunque veais un panel admin a tiro?
5. Si TECNORIBERA te preguntara mañana "¿cuanta ventana de deteccion tengo?", ¿que respuesta le darias basandote en lo que midio IC?
6. Un cliente te dice "lanza nmap a toda nuestra /16 corporativa para ver que pasa". ¿Que le respondes antes de ejecutar nada?

SIGUIENTE SESION (UT2, SEMANA 5)

Con el inventario HE-E10 en la mano, pasamos a priorizar: no todos los hallazgos valen igual. Trabajaremos KEV (Known Exploited Vulnerabilities del CISA) → EPSS (probabilidad de que se explote) → CVSS (gravedad teorica). Objetivo: elegir los TRES hallazgos de hoy que mas te interesan atacar en UT6, con argumento tecnico y economico.